

INTERNATIONAL CYBERSECURITY AND
DIGITAL FORENSICS ACADEMY

Week 4 Practical Laboratory

Linux Security Monitoring and Auditing

From Technical Evidence to Governance Assurance

Student Information	
Full Name	Khodani Netshifhefhe
Registration Number	C11/26/CGRCE/17580
Email Address	c11.cgrce2617580@icdfa.edu.ng
Submission Date	02 October 2026

Table of Contents

Executive Summary.....	2
Scope and Authorization.....	2
Methodology.....	3
Findings	3
Module 1 System Auditing with auditd	3
Required Evidence Module 1.....	3
Required Evidence Module 2.....	6
Required Evidence Module 3.....	7
Module 4 SIEM, Automation and Continuous Monitoring	9
Governance Discussion	9
Control-Monitoring Table.....	10
Governance Escalation Questions.....	11
Conclusion.....	12
Appendix.....	12

Executive Summary

This assessment reviewed the assigned Linux system's monitoring and configuration controls using auditd, journalctl, authentication logs and Lynis 3.1.6. Detective controls worked auditd recorded 11,689 events, and privileged activity was traceable to named users with no significant security event observed. Preventive controls were weaker, with a hardening index of 65, one warning and 40 suggestions. The top findings were a firewall that is loaded but enforces no rules (FIRE-4512, high priority), root-level installs and a root-run script with no evidenced approval, and a hardening level below target. The firewall should be fixed first, and each fix should be retested with Lynis.

Scope and Authorization

All activities were performed only inside the Linux virtual machine assigned for the ICDFA GRC102 practical laboratory, with no external systems, production infrastructure or unauthorised devices targeted.

The assessment covered auditd, journalctl and authentication logs, a Lynis 3.1.6 audit and a conceptual review of SIEM monitoring, using only benign events, with no evidence deleted and no logging disabled.

Methodology

The assessment followed the four lab modules in sequence. I verified auditd and queried its records with ausearch and aureport, reviewed the journal and authentication logs with journalctl and grep. I then considered how the evidence would feed a SIEM and turned the findings into a control-monitoring table, keeping screenshots and command output as evidence for each step.

Findings

Module 1 System Auditing with auditd

Required Evidence Module 1

Screenshot or text evidence that auditd is running

```
systemd-UnitFileFrom: /usr/lib/systemd/systemd-sysv-install enable auditd
Executing: /usr/lib/systemd/systemd-sysv-install enable auditd
Created symlink '/etc/systemd/system/multi-user.target.wants/auditd.service' → '/usr/lib/systemd/system/auditd.service'.

(icdfa@icdfa)-[~]
$ sudo systemctl status auditd
● auditd.service - Security Audit Logging Service
   Loaded: loaded (/usr/lib/systemd/system/auditd.service; enabled; preset: disabled)
   Active: active (running) since Thu 2026-10-01 20:52:29 WAT; 10s ago
  Invocation: 059b108f468248389086e9971e1997d8
     Docs: man:auditd(8)
           https://github.com/linux-audit/audit-documentation
   Main PID: 2461738 (auditd)
      Tasks: 2 (limit: 2206)
     Memory: 692K (peak: 1.8M)
        CPU: 33ms
   CGroup: /system.slice/auditd.service
           └─2461738 /usr/sbin/auditd

Oct 01 20:52:29 icdfa systemd[1]: Starting auditd.service - Security Audit Logging Service...
Oct 01 20:52:29 icdfa auditd[2461738]: No plugins found, not dispatching events
Oct 01 20:52:29 icdfa auditd[2461738]: Init complete, auditd 4.1.2 listening for events (startup state enable)
Oct 01 20:52:29 icdfa systemd[1]: Started auditd.service - Security Audit Logging Service.

(icdfa@icdfa)-[~]
$
```

Evidence showing your loaded custom audit rules

```
(icdfa@icdfa)-[~]
$ sudo auditctl -l
-w /etc/passwd -p rwx -k passwd_changes
-w /etc/shadow -p rwx -k shadow_changes
-a always,exit -F arch=b64 -S execve -F key=program_execution
-a always,exit -F arch=b32 -S execve -F key=program_execution
-w /var/log/auth.log -p wa -k auth_failures
```

At least one ausearch result for a configured audit key

```

(icdfa@icdfa)-[~]
$ sudo ausearch -k program_execution -i | tail -20
type=PATH msg=audit(02/10/2026 18:43:50.624:3593) : item=0 name=/usr/bin/tail inode=786128 dev=08:01 mode=file,755 ouid=root ogid=root rdev=00:00 nametype=NORMAL cap_fp=none cap_fi=none cap_fe=0
cap_fver=0 cap_frootid=0
type=CWD msg=audit(02/10/2026 18:43:50.624:3593) : cwd=/home/icdfa
type=EXECVE msg=audit(02/10/2026 18:43:50.624:3593) : argc=2 a0=tail a1=-20
type=SYSCALL msg=audit(02/10/2026 18:43:50.624:3593) : arch=x86_64 syscall=execve success=yes exit=0 a0=0x7ffefecb9410 a1=0x7f10581efc8 a2=0x558ff24dbf60 a3=0x8 items=3 ppid=2458997 pid=2962396
audit=icdfa uid=icdfa gid=icdfa euid=icdfa suid=icdfa fsuid=icdfa egid=icdfa sgid=icdfa fsgid=icdfa tty=pts0 ses=2 comm=tail exe=/usr/bin/tail subj=unconfined key=program_execution

type=PROCTITLE msg=audit(02/10/2026 18:43:50.652:3598) : proctitle=/usr/sbin/unix_chkpwd icdfa chkexpiry
type=PATH msg=audit(02/10/2026 18:43:50.652:3598) : item=2 name=/lib64/ld-linux-x86-64.so.2 inode=792912 dev=08:01 mode=file,755 ouid=root ogid=root rdev=00:00 nametype=NORMAL cap_fp=none cap_fi=none
cap_fe=0 cap_fver=0 cap_frootid=0
type=PATH msg=audit(02/10/2026 18:43:50.652:3598) : item=1 name=/usr/sbin/unix_chkpwd inode=787023 dev=08:01 mode=file,sgid,755 ouid=root ogid=shadow rdev=00:00 nametype=NORMAL cap_fp=none cap_fi=none
cap_fe=0 cap_fver=0 cap_frootid=0
type=PATH msg=audit(02/10/2026 18:43:50.652:3598) : item=0 name=/usr/sbin/unix_chkpwd inode=787023 dev=08:01 mode=file,sgid,755 ouid=root ogid=shadow rdev=00:00 nametype=NORMAL cap_fp=none cap_fi=none
cap_fe=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(02/10/2026 18:43:50.652:3598) : cwd=/home/icdfa
type=EXECVE msg=audit(02/10/2026 18:43:50.652:3598) : argc=3 a0=/usr/sbin/unix_chkpwd a1=icdfa a2=chkexpiry
type=SYSCALL msg=audit(02/10/2026 18:43:50.652:3598) : arch=x86_64 syscall=execve success=yes exit=0 a0=0x7f30a59250a0 a1=0x7ffdad59ac0 a2=0x7f30a5928018 a3=0x0 items=3 ppid=2962395 pid=2962397
audit=icdfa uid=root gid=icdfa euid=root suid=root fsuid=root egid=shadow sgid=shadow fsgid=shadow tty=pts0 ses=2 comm=unix_chkpwd exe=/usr/sbin/unix_chkpwd subj=unconfined key=program_execution

type=PROCTITLE msg=audit(02/10/2026 18:43:50.660:3611) : proctitle=ausearch -k program_execution -i
type=PATH msg=audit(02/10/2026 18:43:50.660:3611) : item=2 name=/lib64/ld-linux-x86-64.so.2 inode=792912 dev=08:01 mode=file,755 ouid=root ogid=root rdev=00:00 nametype=NORMAL cap_fp=none cap_fi=none
cap_fe=0 cap_fver=0 cap_frootid=0
type=PATH msg=audit(02/10/2026 18:43:50.660:3611) : item=1 name=/usr/sbin/ausearch inode=860863 dev=08:01 mode=file,755 ouid=root ogid=root rdev=00:00 nametype=NORMAL cap_fp=none cap_fi=none
cap_fe=0 cap_fver=0 cap_frootid=0
type=PATH msg=audit(02/10/2026 18:43:50.660:3611) : item=0 name=/usr/sbin/ausearch inode=860863 dev=08:01 mode=file,755 ouid=root ogid=root rdev=00:00 nametype=NORMAL cap_fp=none cap_fi=none
cap_fe=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(02/10/2026 18:43:50.660:3611) : cwd=/home/icdfa
type=EXECVE msg=audit(02/10/2026 18:43:50.660:3611) : argc=4 a0=ausearch a1=-k a2=program_execution a3=-i
type=SYSCALL msg=audit(02/10/2026 18:43:50.660:3611) : arch=x86_64 syscall=execve success=yes exit=0 a0=0x56387ed57e40 a1=0x56387ed57e40 a2=0x56387ed5a0a0 a3=0x0 items=3 ppid=2962398 pid=2962399
audit=icdfa uid=root gid=root euid=root suid=root fsuid=root egid=root sgid=root fsgid=root tty=pts4 ses=2 comm=ausearch exe=/usr/sbin/ausearch subj=unconfined key=program_execution

```

At least one aureport summary

```

(icdfa@icdfa)-[~]
$ sudo aureport
[sudo] password for icdfa:

Summary Report
=====
Range of time in logs: 01/10/2026 20:52:29.567 - 02/10/2026 19:05:49.016
Selected time for report: 01/10/2026 20:52:29 - 02/10/2026 19:05:49.016
Number of changes in configuration: 11
Number of changes to accounts, groups, or roles: 0
Number of logins: 0
Number of failed logins: 0
Number of authentications: 10
Number of failed authentications: 0
Number of users: 3
Number of terminals: 15
Number of host names: 2
Number of executables: 37
Number of commands: 46
Number of files: 55
Number of AVC's: 0
Number of MAC events: 0
Number of failed syscalls: 1
Number of anomaly events: 3
Number of responses to anomaly events: 0
Number of crypto events: 0
Number of integrity events: 0
Number of virt events: 0
Number of keys: 4
Number of process IDs: 10516
Number of events: 11689

```

A short interpretation explaining what the observed audit record says about user/action/time and why the event could matter to security governance.

We first confirmed on Activity 1.1 that auditd was running using the `systemctl status auditd` command. Then on activity 1.2 we configured audit rules and confirmed that they were loaded using the `auditctl -l` command. This is because audit evidence is only reliable if the service and rules are active.

I then queried the audit log by key running `ausearch -k passwd_changes` which showed that at 18:37:43 the rule was successfully added by icdfa, and from 18:38:30 the same user, through `/usr/bin/sudo` on the terminal, opened `/etc/passwd` successfully. This is expected, because sudo reads this file on every use, and the records show no modification of the file. `ausearch -k program_execution` showed that on 2 October 2026 at 18:43:50, the user icdfa executed programs on the terminal, all successfully. `ausearch -k auth_failures` returned one record showing that at 18:37:43 icdfa, running auditctl as root, successfully added the authentication-log rule. It does not indicate any login failures. These events came from my own lab activity, so they were expected.

The aureport summary recorded 11,689 events, 3 users and 4 matched audit keys, confirming the rules are triggering. `aureport --login` returned no events, and the summary showed no failed logins, no failed authentications and no account changes. The `aureport --failed` report showed 4 failed system calls, which were permission-denied errors from my own commands, not an attack. No significant security event was observed.

Required Evidence Module 2

Evidence of recent system-log review using journalctl.

```
May 10 20:50:54 icdfa kernel: pci 0000:00:02.0: vgaarb: setting as boot VGA device
May 10 20:50:54 icdfa kernel: pci 0000:00:02.0: vgaarb: bridge control possible
May 10 20:50:54 icdfa kernel: pci 0000:00:02.0: vgaarb: VGA device added: decodes=io+mem,owns=io+mem,locks=none
May 10 20:50:54 icdfa kernel: vgaarb: loaded
May 10 20:50:54 icdfa kernel: clocksource: Switched to clocksource kvm-clock

(icdfa@icdfa)-[~]
$ sudo journalctl -f
Oct 01 22:18:24 icdfa sudo[2503789]: pam_unix(sudo:session): session opened for user root(uid=0) by icdfa(uid=1000)
Oct 01 22:19:29 icdfa NetworkManager[764]: <info> [1790889569.6613] dhcp4 (eth0): state changed new lease, address=192.168.10.122
Oct 01 22:19:29 icdfa dbus-daemon[690]: [system] Activating via systemd: service name='org.freedesktop.nm_dispatcher' unit='dbus-org.freedesktop.nm_dispatcher.service' requested by ':1.4' (uid=0 pid=764 comm="/usr/sbin/NetworkManager --no-daemon")
Oct 01 22:19:29 icdfa systemd[1]: Starting NetworkManager-dispatcher.service - Network Manager Script Dispatcher Service ...
Oct 01 22:19:29 icdfa dbus-daemon[690]: [system] Successfully activated service 'org.freedesktop.nm_dispatcher'
Oct 01 22:19:29 icdfa systemd[1]: Started NetworkManager-dispatcher.service - Network Manager Script Dispatcher Service.
Oct 01 22:19:39 icdfa systemd[1]: NetworkManager-dispatcher.service: Deactivated successfully.
Oct 01 22:20:00 icdfa sudo[2503789]: pam_unix(sudo:session): session closed for user root
Oct 01 22:20:10 icdfa sudo[2504741]: icdfa : TTY=pts/0 ; PWD=/home/icdfa ; USER=root ; COMMAND=/usr/bin/journalctl -f
Oct 01 22:20:10 icdfa sudo[2504741]: pam_unix(sudo:session): session opened for user root(uid=0) by icdfa(uid=1000)
```

Authentication or privilege-use evidence showing at least one relevant event or confirming that no significant event was observed.

```
(icdfa@icdfa)-[~]
$ sudo journalctl | grep -i "failed password"
Oct 01 22:25:51 icdfa sudo[2507499]: icdfa : TTY=pts/0 ; PWD=/home/icdfa ; USER=root ; COMMAND=/usr/bin/grep -i 'failed password' /var/log/auth.log

(icdfa@icdfa)-[~]
$ sudo journalctl | grep -i "sudo"
May 10 21:20:11 icdfa sudo[13196]: pam_unix(sudo:auth): authentication failure; logname=icdfa uid=1000 euid=0 tty=/dev/pts/0 ruser=icdfa rhost= user=icdfa
May 10 21:20:17 icdfa sudo[13196]: icdfa : TTY=pts/0 ; PWD=/home/icdfa ; USER=root ; COMMAND=/usr/bin/apt -y update
May 10 21:20:17 icdfa sudo[13196]: pam_unix(sudo:session): session opened for user root(uid=0) by icdfa(uid=1000)
May 10 21:30:02 icdfa sudo[18007]: icdfa : TTY=pts/0 ; PWD=/home/icdfa ; USER=root ; COMMAND=/usr/bin/dpkg --add-architecture i386
May 10 21:30:02 icdfa sudo[18007]: pam_unix(sudo:session): session opened for user root(uid=0) by icdfa(uid=1000)
May 10 21:30:02 icdfa sudo[18007]: pam_unix(sudo:session): session closed for user root
```

Error/warning evidence from syslog or an equivalent source

```

[icdfa@icdfa]~$ sudo journalctl -p err
[sudo] password for icdfa:
May 10 20:50:54 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* vmwgfx seems to be running on an unsupported hypervisor.
May 10 20:50:54 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* This configuration is likely broken.
May 10 20:50:54 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* Please switch to a supported graphics device to avoid problems.
May 10 20:57:08 icdfa lightdm[761]: gkr-pam: unable to locate daemon control file
May 10 20:57:08 icdfa lightdm[645]: pam_systemd(lightdm-greeter:session): Failed to release session: Transport endpoint is not connected
May 10 20:57:21 icdfa obexd[1254]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.
May 10 20:57:21 icdfa obexd[1254]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.
-- Boot f8a18b2290a640c9b9236a0ff3f2a536 --
May 11 04:45:41 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* vmwgfx seems to be running on an unsupported hypervisor.
May 11 04:45:41 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* This configuration is likely broken.
May 11 04:45:41 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* Please switch to a supported graphics device to avoid problems.
May 11 04:51:38 icdfa lightdm[802]: gkr-pam: unable to locate daemon control file
May 11 04:51:38 icdfa lightdm[690]: pam_systemd(lightdm-greeter:session): Failed to release session: Transport endpoint is not connected
May 11 04:51:48 icdfa obexd[1324]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.
May 11 04:51:48 icdfa obexd[1324]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.
-- Boot 1330474cb531439e929342180494b74a --
May 11 06:10:01 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* vmwgfx seems to be running on an unsupported hypervisor.
May 11 06:10:01 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* This configuration is likely broken.
May 11 06:10:01 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* Please switch to a supported graphics device to avoid problems.
May 11 06:10:30 icdfa lightdm[785]: gkr-pam: unable to locate daemon control file

```

A short table containing Event/Condition, Evidence Source, Time, User/Service, Security Significance and Recommended Action.

Event/Condition	Evidence Source	Time	User/Service	Security Significance	Recommended Action
Failed sudo authentication	journalctl _COMM=sudo (auth.log equivalent)	May 10 2026 21:20:11	ICDFA via sudo	A failed password at privilege escalation. Sudo succeeded six seconds later (21:20:17), so it is most likely a typing error. Repeated failures would suggest password guessing.	Monitor for repeats, alert on repeated failures, and consider account lockout.
Root-level software installation: dpkg --add-architecture i386, apt -y update, apt -y install wine64 wine32; later also wine and python3-pip	journalctl _COMM=sudo	May 10 2026 21:30:02 to 21:38:46 and May 11 04:55:18 to 04:55:22	icdfa as root	Traceable, but installing software as root changes the system's attack surface and should be authorised.	Cover with change management and restrict which accounts may install packages.
Privileged sudo session during the live journal review	journalctl -f	Oct 01 2026 22:18:24 to 22:20:00	icdfa (uid 1000) as root, via sudo	Privileged use is logged and traceable to a named user. Expected, as it	Control owner reviews sudo logs periodically to confirm

				was my own lab activity.	privileged use is authorised.
--	--	--	--	--------------------------	-------------------------------

Required Evidence Module 3

Lynis version and audit execution evidence

```
(icdfa@icdfa)-[~]
$ sudo systemctl status lynis
o lynis.service - Security audit and vulnerability scanner
  Loaded: loaded (/usr/lib/systemd/system/lynis.service; static)
  Active: inactive (dead)
  TriggeredBy: ● lynis.timer
  Docs: https://cisofy.com/docs/

(icdfa@icdfa)-[~]
$ lynis show version
3.1.6
```

Hardening index or equivalent summary, if reported

```
- Vulnerability Scan [V]

Details:
Hardening index : 65 [#####]
Tests performed : 273
Plugins enabled : 1
```

At least three warnings/suggestions or notable findings.

```
-[ Lynis 3.1.6 Results ]-

Warnings (1):
! iptables module(s) loaded, but no rules active [FIRE-4512]
  https://cisofy.com/lynis/controls/FIRE-4512/

Suggestions (40):
* Install libpam-tmpdir to set $TMP and $TMPDIR for PAM sessions [DEB-0280]
  - Related resources
    * Website: https://cisofy.com/lynis/controls/DEB-0280/

* Install apt-listbugs to display a list of critical bugs prior to each APT installation. [DEB-0810]
  - Related resources
    * Website: https://cisofy.com/lynis/controls/DEB-0810/

* Install apt-listchanges to display any significant changes prior to any upgrade via APT. [DEB-0811]
  - Related resources
    * Website: https://cisofy.com/lynis/controls/DEB-0811/
```

For each selected finding: risk/control issue, evidence, likely owner, recommended remediation and priority.

Finding	Risk / Control Issue	Evidence	Likely Owner	Recommended Remediation	Priority
iptables module(s) loaded, but no rules active (Warning)	The host firewall is not enforcing anything, so network access is not restricted. The network protection control is ineffective.	Lynis 3.1.6 Results, Warnings (1)	System administrator / Network security team	Define a rule set (default-deny inbound, allow only required services), apply it, and rerun Lynis to confirm the warning clears.	High
install apt-listbugs (Suggestion)	Weaker patch management: packages can be installed without reviewing known critical bugs first.	Lynis Results, Suggestions (40)	Patch management / Change control owner	Install apt-listbugs and include its output in the change review process.	Low
install apt-listchanges (Suggestion)	Weaker change control: significant changes in an upgrade are not shown before they are applied.	Lynis Results, Suggestions (40)	Patch management / Change control owner	Install apt-listchanges and review its notices before approving upgrades.	Low
install libpam-tmpdir (Suggestion)	Shared /tmp use by all users raises the risk of temporary-file attacks such as symlink races.	Lynis Results, Suggestions (40)	System administrator	Install libpam-tmpdir so each user session gets a private temp directory.	Low

Module 4 SIEM, Automation and Continuous Monitoring

Governance Discussion

Explain how the evidence you collected from auditd, journalctl, authentication logs and Lynis could be forwarded to or represented in an enterprise monitoring environment.

Evidence Collected	How it could be forwarded or represented	What the SIEM does with it
auditd (keys passwd_changes, shadow_changes, program_execution, auth_failures)	An agent or syslog forwarder (e.g. audisp-remote, rsyslog or a SIEM agent) ships /var/log/audit/audit.log	Parses fields such as auid, exe, key and success, so searches and alerts can use them
journalctl (sudo sessions, failed sudo authentication, SSH events)	The journal is forwarded via syslog or a collector from every host	Normalises different formats into one schema and correlates events by user, host and time
Lynis (hardening index 65, warning FIRE-4512, 38 suggestions)	lynis-report.dat is scheduled and ingested as periodic posture data	Tracks the hardening score and open findings per host over time, so trends and non-compliant hosts are visible on a dashboard

Identify what should remain a technical operational alert

An operational alert is about an event that needs a fast technical response. A governance issue is about a control that is missing, ineffective, unowned or repeatedly failing, which needs accountability, a deadline and a retest.

Condition	Treatment	Reasoning
Repeated failed logins, an unexpected write to /etc/shadow, or a root script from an unusual location	Operational alert	Possible active attack needing fast triage by security operations
auditd stopped, rules missing or logs not arriving	Both operational and governance	Restore it as an operational alert and if it persists, the monitoring control itself has failed, which is a governance issue
Lynis warning FIRE-4512 (firewall with no rules) still open	Governance	A control exists on paper but enforces nothing, so it needs an owner, a date and a retest
Root software installs and ./.sh run as root without evidence of approval	Governance Issue	Privileged changes need authorisation through change management

Control-Monitoring Table

Control / Objective	Evidence	Owner	Observed Status	KPI/KRI or Threshold	Risk / Significance	Remediation	Retest / Follow-up
Network protection - host firewall filters traffic	Lynis warning FIRE-4512: iptables loaded, no rules active	System administrator / Network security lead	Not effective - no rules enforced	For KRI we need 0 open Lynis warnings	High	Define and approve a default-deny rule set, then apply it	Rerun lynis audit system and confirm the warning clears
Privileged access and change control - root actions are authorised and traceable	journalctl _COMM=sudo: root installs (wine64/wine32, python3-pip) and ./1.sh run as root	System owner / Change manager	Traceable, but approval not evidenced	For KPI 100% of root changes linked to an approved change record	Medium	Review the script, link each root change to a ticket, restrict package installs	Monthly sudo log review against change records
Authentication monitoring - failed logins are detected	One failed sudo authentication at 21:20:11, success at 21:20:17; 0 failed logins in aureport	Security operations lead	Operating	More than 5 failures in 10 minutes triggers an alert for KRI	Low	Keep monitoring and add a repeat-failure alert	Quarterly review of failure counts
System auditing - auditd records privileged and sensitive activity	auditd active since 1 Oct 20:52:29; auditctl -l shows 5 rules; aureport shows 11,689 events and 4 keys	System administrator / Audit owner	Operating	auditd running and rules loaded on 100% of checks for KPI	Medium	Confirm rules load at boot, and alert if auditd stops	Scheduled auditctl -l and status check
Configuration hardening - systems meet the agreed baseline	Lynis hardening index 65, 273 tests, 38 suggestions	System owner / IT operations	Partially compliant	For KPI a downward trend on warnings and suggestions	Medium	Prioritise suggestions by risk, each with an owner and date	Rerun Lynis after each change and track the index

Governance Escalation Questions

1. Which finding is the highest priority and why?

FIRE-4512 (firewall loaded, no rules active) is the highest priority. It is the only Lynis warning, and it is still open after the retest. A control that exists on paper but enforces nothing leaves the host open to unrestricted inbound traffic, so the control is failing.

2. Who should own remediation for each major finding?

The system administrator, working with the network security lead, should own the firewall fix, because they design and apply the rule set. The system owner or change

manager should own the review of root level activity, including checking the script and linking each change to an approval record. The system owner or IT operations should own the hardening suggestions, and the system administrator should keep auditd and logging running. The CISO is accountable for the overall control framework, while these named owners are responsible for the fixes.

3. What threshold or condition should trigger escalation to the CISO, Risk function or management committee?

Technical events such as repeated failed logins, an unexpected write to /etc/shadow or auditd stopping should go to the control owner and security operations. A high priority finding that stays unresolved past its due date, a persistent logging failure or privileged changes with no approval record should be escalated to the CISO. A control that stays ineffective and needs a formal exception should go to the Risk function. Repeated or systemic failures, or evidence of unauthorised privileged activity, should reach the management committee. These thresholds are proposed and should be aligned with the organisation's approved baselines.

4. What evidence would demonstrate successful remediation?

For the firewall, evidence would be the approved rules shown by `sudo iptables -L` and a new Lynis report where FIRE-4512 no longer appears and the warning count is zero. For root activity, it would change tickets linked to each action and a reviewed script. For hardening, it would be a higher hardening index and fewer suggestions in a new report, as in the DEB-0280 retest where suggestions fell from 40 to 38. For auditd, it would be an active service status and the loaded rules shown by `auditctl -l`. All evidence should be dated and kept with the report.

5. When and how should the control be retested?

Each control should be retested immediately after remediation, then monthly for high-priority controls and quarterly for the others, with an extra retest after any significant system change. The retest means re-running sudo lynis audit system and comparing warnings, suggestions and the hardening index with the previous report, rechecking the auditd status and rules, and reviewing the sudo and failed login logs. A finding should be closed only when the new evidence meets the success criteria. In an enterprise setting these checks would run automatically, with failures raising tickets that escalate if they become overdue.

Conclusion

This assessment found that the Linux system's monitoring controls are operating, with traceable evidence and no significant security event, while its preventive controls need attention. The unenforced firewall (FIRE-4512) is the priority weakness, followed by root level changes without evidenced approval and a hardening index of 65. Each finding should have a named owner, a due date and a retest, with overdue high-priority items escalated to the CISO.

Appendix

[Screenshots](#)